

개인정보위, 개인정보 유출 명품브랜드사에 과징금 360억여 원 부과

- 개인정보를 처리하는 서비스형 소프트웨어(SaaS)에도 접속 IP 제한 및 안전한 인증수단 적용, 접속기록 보관·점검 등 안전조치 준수 필요

개인정보보호위원회(위원장 송경희, 이하 ‘개인정보위’)는 2월 11일(수) 제3회 전체회의를 열고, 「개인정보 보호법」(이하 ‘보호법’)을 위반한 명품브랜드 판매 3개 사업자*에 총 360억 3,300만 원의 과징금과 1,080만 원의 과태료를 부과하고 처분 사실의 공표를 명령하였다.

* ①루이비통코리아(유), ②크리스찬디올꾸뛰르코리아 주식회사, ③주식회사 티파니코리아

이들 3개 사업자는 모두 서비스형 소프트웨어(SaaS*) 기반 고객관리 서비스를 이용하는 과정에서 개인정보 유출사고가 발생하였으며, 구체적인 위반 내용과 처분 결과는 다음과 같다.

* SaaS(Software as a Service, 서비스형 소프트웨어) : 소프트웨어를 서버 등에 설치하지 않고 인터넷을 통해 클라우드 형태로 제공하는 방식

< 루이비통 : 과징금 213억 8,500만 원과 결과 공표 >

루이비통은 직원의 기기가 악성코드에 감염되어 서비스형 소프트웨어 계정 정보를 해커에게 탈취당했고, 이에 따라 약 360만 명의 개인정보가 총 3차례(‘25. 6. 9. ~ 13.)에 걸쳐 유출되었다.

루이비통은 2013년부터 구매 고객 등 관리를 위해 해당 서비스형 소프트웨어 도입·운영하면서, 접근할 수 있는 권한을 인터넷프로토콜(이하 ‘IP’) 주소 등으로 제한하지 않았으며, 개인정보취급자가 외부에서 접속할 때 안전한 인증수단을 적용하지 않은 것으로 나타났다.

이에 개인정보위는 루이비통에 과징금을 부과하고, 처분받은 사실을 사업자 누리집(홈페이지)에 공표하도록 명령하였다.

< 디올 : 과징금 122억 3,600만 원과 과태료 360만 원 부과, 결과 공표 >

디올은 고객센터 직원이 해커의 보이스피싱에 속아 서비스형 소프트웨어에 대한 접근권한을 해커에게 부여함에 따라 약 195만 명의 개인정보가 유출되었다.

디올은 구매 고객 등 관리를 위해 2020년부터 해당 서비스형 소프트웨어를 도입·운영하면서, 접근할 수 있는 권한을 IP 주소 등으로 제한하지 않았으며, 대량의 데이터 다운로드 지원 도구의 사용을 제한하지 않았다. 또한, 개인정보 다운로드 여부 등 접속기록을 월 1회 이상 점검하지 않아 유출 사실을 3개월 이상 확인하지 못하였다.

아울러, 개인정보 유출 인지('25.5.7.) 후 정당한 사유 없이 72시간을 경과하여 유출 통지('25.5.12.)한 사실도 확인하였다.

이에 개인정보위는 디올에 과징금 및 과태료를 부과하고, 처분받은 사실을 사업자 누리집(홈페이지)에 공표하도록 명령하였다.

< 티파니 : 과징금 24억 1,200만 원과 과태료 720만 원 부과, 결과 공표 >

티파니는 디올의 유출 경위와 마찬가지로, 고객센터 직원이 해커의 보이스피싱에 속아 서비스형 소프트웨어에 대한 접근권한을 해커에게 부여함에 따라, 약 4,600여 명의 개인정보가 유출되었다.

티파니는 2021년부터 마케팅을 위해 해당 서비스형 소프트웨어를 도입·운영하면서, 접근할 수 있는 권한을 IP 주소 등으로 제한하지 않았으며, 대량의 데이터 다운로드 지원 도구의 사용을 제한하지 않았다.

아울러, 개인정보 유출 인지('25.5.9) 후 정당한 사유 없이 72시간을 경과하여 유출 신고·통지('25.5.22.)한 사실도 확인하였다.

이에 개인정보위는 티파니에 과징금 및 과태료를 부과하고, 처분받은 사실을 사업자 누리집(홈페이지)에 공표하도록 명령하였다.

< 이번 조사·처분의 의의 >

최근 많은 기업은 초기 구축 비용 절감 및 유지관리 효율성 등을 이유로 글로벌 대기업의 서비스형 소프트웨어를 도입하여 운영하고 있다. 그러나, 서비스형 소프트웨어에 대한 신뢰를 토대로 비용·편의 측면만 고려 시 개인정보 안전성 확보에는 소홀히 할 우려가 있어 주의가 요구된다.

고객 관리 등을 위해 서비스형 소프트웨어를 도입하여 개인정보를 처리하는 경우 이는 개인정보처리시스템에 해당하므로 접근 권한을 업무 수행에 필요한 최소한의 범위로 차등 부여하는 등의 조치를 취하여야 한다.

아울러, IP 주소 등을 제한하여 인가받지 않은 접근을 통제하고, 외부에서 개인정보처리시스템에 접속하려는 경우 안전한 인증 수단(일회용 비밀번호(OTP), 인증서, 보안토큰 등)을 필수적으로 적용해야 한다.

개인정보위는 “기업이 서비스형 소프트웨어를 도입하는 경우에도 개인정보를 안전하게 관리하는 책임이 면제 또는 전가되지 않는 만큼 해당 서비스가 제공하는 개인정보 보호 기능을 개인정보처리자가 충분히 적용하여 개인정보 유출사고를 예방해야 할 것”이라고 강조했다.

[붙임] 사업자별 위반 및 시정조치 내역

담당 부서 <총괄>	개인정보보호위원회 조사1과	책임자	과 장	윤여진 (02-2100-3111)
		담당자	조사관	이승철 (02-2100-3118)
			조사관	도혜원 (02-2100-3117)
<공동>	한국인터넷진흥원 유출조사팀	책임자	팀 장	손기종 (061-820-2850)
		담당자	책 임	한상원 (061-820-2859)

붙임**사업자별 위반 및 시정조치 내역**

< 피심인별 시정조치(안) >

연번	피심인 명	위반 내용	위반조항	시정조치(안)
1	루이비통코리아 (유)	• 안전조치의무 위반(접근통제)	보호법§29	• 과징금 213억 8,500만 원 • 공표명령
2	크리스찬디올 꾸뛰르코리아 주식회사	• 안전조치의무 위반(접근권한, 접근통제, 접속기록) • 개인정보 유출 등의 통지 위반	보호법§29, §34①	• 과징금 122억 3,600만 원 • 과태료 360만 원 • 공표명령
3	주식회사 티파니코리아	• 안전조치의무 위반(접근권한, 접근통제) • 개인정보 유출 등의 통지신고 위반	보호법§29, §34①·③	• 과징금 24억 1,200만 원 • 과태료 720만 원 • 공표명령